QR Authenticity & Activation System

ภาพรวมระบบ (System Overview)

เวอร์ชัน: 2.0 **อัพเดตล่าสุด:** กุมภาพันธ์ 2026 **Stack:** Next.js 16 + TypeScript + Tailwind CSS v4 + PostgreSQL + Prisma 6

---

1. ภาพรวมโครงการ

ระบบ **QR Authenticity & Activation** เป็นระบบติดตามและยืนยันความแท้ของสินค้าความงาม (Filler, Botox, Skincare) แบบรายชิ้น (Item-level) ด้วย QR Code ที่เป็น Signed/Encrypted token และ Serial Number 12 หลัก (auto running)

เป้าหมายหลัก

- ลดความเสี่ยง QR ปลอมหรือเดา token ได้ (ใช้ JWE Encryption)
- ทำให้ทุกชิ้นสินค้ามีตัวตนดิจิทัล (Serial 12 หลัก) เชื่อมกับฐานข้อมูล
- ทำงานผ่านมือถือได้ (สแกนผ่านเว็บ) ทั้ง iPhone/Android
- มี Board ให้ Manager อนุมัติการส่งออกก่อนสถานะออกจากคลัง
- Public scan เห็นผลทันที (ไม่ต้องล็อกอิน)
- รองรับ Activation แบบ Single (ครั้งเดียว) และ Pack (หลายครั้ง)
- พิมพ์สติกเกอร์ 4x6 (Thermal) 1 ดวง/หน้า

---

2. Flow การทำงานหลัก

```
┌──────────────┐    ┌──────────────┐    ┌──────────────┐    ┌──────────────┐
│ Pre-Generate│ → │   Inbound    │ → │  Outbound    │ → │   Verify     │
│  QR Codes    │    │    (GRN)     │    │  + Approve   │    │  (Public)    │
└──────────────┘    └──────────────┘    └──────────────┘    └──────────────┘
                                                                  │
                                                                  ▼
                                                            ┌──────────────┐
                                                            │   Activate   │
                                                            │ (Customer)   │
                                                            └──────────────┘
```

Flow 1: สร้าง QR ล่วงหน้า (Pre-Generate)

1. Admin/Warehouse สร้าง Batch ของ QR Codes ล่วงหน้า
2. ระบบสร้าง Serial 12 หลักและ QR Token สำหรับแต่ละชิ้น
3. สินค้ามีสถานะ `PENDING_LINK` (รอเชื่อมโยงกับสินค้าจริง)

Flow 2: รับเข้าคลัง (GRN)

1. Warehouse รับสินค้าเข้าคลัง
2. สแกน QR จาก Pre-Generated Batch เพื่อเชื่อมโยงกับสินค้าจริง
3. กรอกข้อมูลสินค้า (SKU, Lot, Exp, etc.)
4. สินค้าเปลี่ยนสถานะเป็น `IN_STOCK`

Flow 3: ส่งออก (Outbound) + อนุมัติ

1. Warehouse สร้าง Outbound request (เลือกคลินิก + รายการสินค้า)
2. สินค้าเปลี่ยนเป็น `PENDING_OUT`
3. Manager เข้าหน้า Approval Board อนุมัติ/ปฏิเสธ
4. ถ้าอนุมัติ → สินค้าเปลี่ยนเป็น `SHIPPED`
5. ถ้าปฏิเสธ → สินค้ากลับเป็น `IN_STOCK`

Flow 4: ตรวจสอบความแท้ (Verify)

1. คลินิก/ลูกค้าสแกน QR Code
2. ระบบตรวจสอบและแสดงข้อมูลสินค้า
3. แสดงสถานะ: ของแท้/ปลอม/ถูก activate แล้ว

Flow 5: ลงทะเบียน (Activate)

1. ลูกค้ากด "ลงทะเบียน" หลังจาก Verify
2. กรอกข้อมูล + ยินยอม PDPA
3. สินค้า SINGLE → เปลี่ยนเป็น `ACTIVATED` (ครั้งเดียว)
4. สินค้า PACK → นับจำนวน activation จนครบ

---

3. บทบาทผู้ใช้งาน (User Roles)

Role	สิทธิ์การใช้งาน
ADMIN	จัดการทุกอย่าง: Users, Clinics, Product Masters, Master Data, System Settings, Event Logs, Purchase Orders
MANAGER	Approval Board: อนุมัติ/ปฏิเสธ Outbound, ดูรายละเอียด
WAREHOUSE	สร้าง GRN, Pre-generate QR, สร้าง Outbound, พิมพ์ QR, รับคืน, Reprint, Damaged Products
PUBLIC	ไม่ต้องล็อกอิน: สแกน Verify, Activate

---

4. Product Status Flow

```
                    ┌──────────┐
                    │PENDING_LINK│  ← Pre-Generated QR (ยังไม่เชื่อมสินค้า)
                    └──────────┘
                          │ (Link to GRN)
                          ▼
┌──────────────────────────────────────────────────────────┐
│                       IN_STOCK                           │ ← รับเข้าคลังแล้ว
└──────────────────────────────────────────────────────────┘
                          │ (Create Outbound)
                          ▼
                    ┌──────────┐
                    │PENDING_OUT│  ← รออนุมัติส่งออก
                    └──────────┘
                          │
              ┌───────────┴────────────┐
              │ (Approve)              │ (Reject)
              ▼                        ▼
         ┌─────────┐              ┌─────────┐
         │ SHIPPED │              │IN_STOCK │
         └────────┬┘              └─────────┘
                  │ (Activate)
                  ▼
        ┌──────────────┐
        │ ACTIVATED    │  ← ลูกค้าลงทะเบียนแล้ว
        └──────────────┘
                  │ (Return)
                  ▼
        ┌──────────────┐
        │  RETURNED    │  ← คืนสินค้า
        └──────────────┘


        ┌──────────────┐
        │  DAMAGED     │  ← สินค้าเสียหาย (แยกต่างหาก)
        └──────────────┘
```

5. ฟีเจอร์หลัก

5.1 Core Features

Feature	คำอธิบาย
User Authentication	JWT + HttpOnly Cookie (7 วัน)
Role-Based Access	ADMIN/MANAGER/WAREHOUSE
QR Code Generation	JWE Encrypted (A256GCM)
Serial Number	12 หลัก auto-running
Product Verification	Public (ไม่ต้อง login)
i18n Support	ภาษาไทย / English

5.2 Warehouse Features

Feature	คำอธิบาย
Pre-Generate QR	สร้าง QR Batch ล่วงหน้า
GRN (Goods Receipt)	รับสินค้าเข้าคลัง
Outbound	ส่งสินค้าออก
Print Labels	PDF 4x6 inch
Reprint QR	พิมพ์ใหม่ (version +1)
Return	รับคืนสินค้า
Damaged Products	จัดการสินค้าเสียหาย

5.3 Admin Features

Feature	คำอธิบาย
User Management	CRUD users + reset password
Clinic Management	CRUD clinics + reservations
Product Masters	แคตาล็อกสินค้าหลัก
Purchase Orders	ใบสั่งซื้อ (สั่งฝากสินค้า)
Master Data	Categories, Units, Shipping Methods, Warehouses
System Settings	การตั้งค่าระบบ
Event Logs	Audit trail

5.4 Public Features

Feature	คำอธิบาย
Verify	ตรวจสอบความแท้ด้วย QR หรือ Serial
Activate	ลงทะเบียนสินค้า (SINGLE/PACK)

---

6. ความปลอดภัย (Security)

6.1 QR Token Security

- **Encryption:** JWE (JSON Web Encryption) with A256GCM
- **Library:** jose
- **Token Content:** Serial, Version, Timestamp (encrypted)
- **Token Hash:** SHA256 for database lookup

6.2 Authentication

- **Password:** bcrypt hashing
- **Session:** JWT (jose library)
- **Cookie:** HttpOnly, Secure, SameSite=Lax
- **Expiration:** 7 days

6.3 API Security

- **Rate Limiting:** In-memory (per IP)
  - Public endpoints: 60 req/min
  - Auth endpoints: 10 req/15 min
  - Admin endpoints: 100 req/min
- **Role-based middleware:** withAuth, withRoles, withMinRole

6.4 Privacy

- **IP Hashing:** SHA256 hash ใน ScanLog
- **PDPA Consent:** บันทึก timestamp และ policy version

---

7. Tech Stack

Frontend

Technology	Version	Purpose
Next.js	16	React Framework (App Router)
React	19.2.3	UI Library
TypeScript	5.x	Type Safety
Tailwind CSS	4.x	Styling
html5-qrcode	2.3.8	QR Scanner
jsPDF	4.0.0	PDF Generation
qrcode	1.5.4	QR Code Generation
xlsx	0.18.5	Excel Export

Backend

Technology	Version	Purpose
Next.js API Routes	16	API Layer
Prisma	6.19.2	ORM
PostgreSQL	15+	Database
Redis	Latest	Cache (configured)
jose	6.1.3	JWT/JWE
bcryptjs	3.0.3	Password Hashing

Infrastructure

Technology	Purpose
Docker Compose	Development Environment
PostgreSQL Container	Database
Redis Container	Cache/Rate Limiting

8. โครงสร้างโฟลเดอร์

```
edencolors/
├── app/
│   ├── api/                    # API Routes (43 routes)
│   │   ├── auth/               # Authentication
│   │   ├── public/             # Public endpoints
│   │   ├── admin/              # Admin endpoints
│   │   ├── warehouse/          # Warehouse endpoints
│   │   ├── manager/            # Manager endpoints
│   │   └── health/             # Health check
│   ├── [locale]/               # i18n routes (th/en)
│   │   ├── login/
│   │   ├── verify/
│   │   ├── activate/
│   │   └── dashboard/          # Protected pages
│   ├── v/[serial]/             # Short URL for verify
│   ├── layout.tsx
│   └── page.tsx
├── components/
│   ├── dashboard/              # Dashboard components
│   ├── ui/                     # Base UI components
│   ├── qr-scanner.tsx
│   └── public-navbar.tsx
├── lib/
│   ├── auth.ts                 # JWT management
│   ├── session.ts              # Cookie session
│   ├── api-middleware.ts       # Role-based middleware
│   ├── qr-token.ts             # QR encryption
│   ├── serial-generator.ts     # Auto-running numbers
│   ├── rate-limit.ts           # Rate limiting
│   ├── prisma.ts               # Prisma client
│   ├── pdf-label.ts            # PDF labels
│   └── pdf-delivery.ts         # PDF delivery notes
├── prisma/
│   ├── schema.prisma           # Database schema
│   └── seed.ts                 # Seed data
├── i18n/
│   └── dictionaries/           # th.json, en.json
├── middleware.ts               # Route protection
├── package.json
├── docker-compose.yml
└── CLAUDE.md
```

9. URL Structure

QR Code URL Format

- **Short URL (ใหม่):** `https://app.url/v/123456789012`
- **Legacy URL:** `https://app.url/th/verify?token=...`

Web URLs

URL	Description
`/`	Landing page
`/th/login`	Login (Thai)
`/en/login`	Login (English)
`/th/verify`	Verify page
`/th/activate`	Activation page
`/th/dashboard`	Dashboard
`/v/{serial12}`	Short verify URL

---

10. Test Accounts

Role	Username	Password
Admin	admin	admin123
Warehouse	warehouse1	warehouse123
Manager	manager1	manager123

---

11. Environment Variables

```
# Database
DATABASE_URL=postgresql://postgres:postgres@localhost:5432/edencolors

# Redis
REDIS_URL=redis://localhost:6379

# Security
JWT_SECRET=your-jwt-secret-key-min-32-chars
QR_TOKEN_SECRET=your-qr-secret-32-chars!!!

# Application
NEXT_PUBLIC_APP_URL=http://localhost:3000
NODE_ENV=development
```

---

12. Quick Start

```
# 1. Start database
npm run db:up

# 2. Generate Prisma client
npm run db:generate

# 3. Push schema to database
npm run db:push

# 4. Seed test data
npm run db:seed

# 5. Start development server
npm run dev
```

เปิดเบราว์เซอร์ไปที่: `http://localhost:3000`